

**MEDICARE CONNECT (PTY) LTD
THIRD-PARTY VENDOR SECURITY ASSESSMENT REPORT**

Vendor Assessed : PathLab SA (Pty) Ltd
Service Assessed : Pathology Diagnostic Data Integration API
Vendor Criticality : Tier 1 (Critical Risk)

Classification : Confidential
Date of Assessment : March 2026
Assessor : Patrick Mohlala, GRC Analyst
Distribution : Information Officer, IT Manager, CEO

1. EXECUTIVE SUMMARY

MediCare Connect engaged PathLab SA (Pty) Ltd to integrate automated pathology test results directly into the Patient Health Record System.

As a Tier 1 vendor processing Special Personal Information (patient diagnostic data), PathLab SA underwent a formal security evaluation using our 25-Question VSAQ.

Overall Security Score: 68% (Needs Remediation)
Status: Provisional Conditional Approval (Pending Remediation)

2. DOMAIN EVALUATION SCORECARD

Security Domain	Weight	Maximum Score	Actual Score	Percentage	Rating
1. Governance & Compliance	20%	20	14	70%	Acceptable
2. Access Control & Auth	20%	20	10	50%	High Risk
3. Data Protection & Encryption	25%	25	20	80%	Good
4. IR & Business Continuity	20%	20	12	60%	Needs Improvement
5. POPIA Operator Obligations	15%	15	12	80%	Acceptable
TOTAL	100%	100	68	68%	Provisional

3. CRITICAL DEFICIENCIES IDENTIFIED

DEFICIENCY 1 : Lack of Multi-Factor Authentication (MFA) on Admin Portals

- Findings: PathLab SA engineers access the API integration gateway using single-factor password authentication.
- Risk: Compromise of an engineer's credentials allows unauthorized access to all transferred patient lab results.
- Mandatory Remediation: Enforce MFA on all administrative gateways prior to final system sign-off.

DEFICIENCY 2: Missing POPIA Section 21 Operator Agreement

- Findings: PathLab SA has been operating under a generic service-level agreement with no formal POPIA DPA.
- Risk: MediCare Connect carries unmitigated legal liability for vendor data handling failures under POPIA Section 21.
- Mandatory Remediation: Execute MediCare Connect's standard POPIA Section 21 Agreement immediately.

DEFICIENCY 3: Incident Breach Notification Timeline Exceeds Threshold

- Findings: PathLab SA's internal policy promises breach notification within 5 business days.
- Risk: Conflicts with MediCare Connect's requirement for 24-hour vendor notification to support the POPIA 72-hour regulatory clock.
- Mandatory Remediation: Contractually enforce 24-hour notification clause via the Section 21 Agreement.

4. CORRECTIVE ACTION PLAN & DECISION

CONDITIONAL APPROVAL TERMS:

PathLab SA is granted 45 days to complete the following corrective actions:

1. Execute POPIA Section 21 Operator Agreement (Deadline: 7 Days).
2. Enable Multi-Factor Authentication on API Admin Portals (Deadline: 30 Days).
3. Align Incident Notification Policy to 24-Hour Threshold (Deadline: 14 Days).

If PathLab SA fails to complete these items within 45 days, API connectivity will be suspended.

Document Control

Prepared by : Patrick Mohlala, GRC Analyst
Date : March 2026
Status : Final
Review : September 2026